TECHNICAL GOVERNANCE & PRIVACY COMPLIANCE STANDARD

INFORMATION SECURITY & DATA STEWARDSHIP POLICY

Document ID: SEC-DAT-005
Entity: FD System Holdings
Effective Date: 10/22/2026
Standard: ISO 27001 / SOC 2 Type II

CRYPTOGRAPHIC DEFENSE & FIDUCIARY DATA STEWARDSHIP

This Information Security and Data Stewardship Policy establish mandatory engineering, operational, and legal safeguards governing FD System Holding's software infrastructure, client privacy architectures, and data integrity controls. All cloud environments, production databases, source code repositories, and personnel endpoints must enforce Zero-Trust access principles and cryptographic protection by default.

ARTICLE I: GOVERNANCE AUTHORITY & ZERO-TRUST ARCHITECTURE

Section 1.01 Security Governance Mandate. The Chief Information Security Officer (CISO), under the oversight of the Audit & Oversight Committee, holds authority to enforce security standards across all production networks, corporate IT systems, and third-party vendor integrations. Any exception to this Policy requires a formal risk-acceptance waiver co-signed by the CISO and General Counsel.

Section 1.02 Zero-Trust Identity & Access Management (IAM). Access to corporate infrastructure and client data is governed by the Principle of Least Privilege (PoLP). Multi-Factor Authentication (MFA) utilizing hardware security keys or FIDO2/WebAuthn standards is mandatory for all personnel. Standing administrative privileges in production environments are prohibited; privileged elevation requires just-in-time (JIT) dual-authorization and session logging.

ARTICLE II: DATA CLASSIFICATION & CRYPTOGRAPHIC STANDARDS

Section 2.01 Mandatory Classification Tiers. All corporate and client data ingested, processed, or stored by [Company Name] must be tagged and handled according to four strict security tiers, enforcing automated cryptographic and retention controls at the storage layer.

CLASSIFICATION TIER	COVERED DATA ELEMENTS	MANDATORY CRYPTOGRAPHIC & ACCESS CONTROL
Tier 1: Restricted	Client PII/PHI, cryptographic private keys, authentication tokens, payment credentials, MNPI.	AES-256-GCM at rest (HSM-backed KMS); TLS 1.3 in transit; strict customer-tenant isolation; immutable audit logs.
Tier 2: Confidential	Proprietary source code, non-public financial ledgers, client contracts, system architecture maps.	AES-256 encryption at rest; TLS 1.2+ in transit; role-based access control (RBAC) with quarterly entitlement audit.
Tier 3: Internal Use	Internal operational policies, employee directories, non-sensitive project documentation.	Authenticated corporate SSO access required; encrypted endpoint storage (FileVault / BitLocker).
Tier 4: Public	Published legal charters, marketing collateral, public press releases, open-source notices.	Cryptographic integrity checksums (SHA-256) to prevent unauthorized web defacement or tampering.

ARTICLE III: SOFTWARE INFRASTRUCTURE SECURITY & SDLC CONTROLS

Section 3.01 Secure Software Development Lifecycle (S-SDLC). All proprietary software and infrastructure-as-code (IaC) developed by [Company Name] must pass automated Static Application Security Testing (SAST), Dynamic Application Security Testing (DAST), and Software Composition Analysis (SCA) prior to production deployment. Direct commits to production branches are cryptographically blocked; all code changes require peer code review and signed commits.

Section 3.02 Environment Segregation & Production Data Ban. Development, testing, and staging environments must be strictly segregated at the network and identity layer from production infrastructure. The use of unmasked Tier 1 Restricted client data within development or testing environments is strictly prohibited.

Section 3.03 Vulnerability Remediation SLAs. External attack surfaces shall undergo continuous automated scanning and annual independent CREST-certified penetration testing. Identified vulnerabilities must be patched within strict remediation windows: Critical severity (CVSS ≥ 9.0) within forty-eight (48) hours; High severity (CVSS 7.0–8.9) within seven (7) calendar days; and Medium severity within thirty (30) calendar days.

ARTICLE IV: CLIENT PRIVACY STEWARDSHIP & REGULATORY COMPLIANCE

Section 4.01 Data Minimization & Purpose Limitation. FD System Holdings acts as a fiduciary steward of client data. Personal data shall be collected solely for specified, explicit, and legitimate contractual purposes, in full compliance with GDPR, CCPA/CPRA, HIPAA, and applicable international privacy statutes. Client data shall never be monetized, sold, or used to train external foundation models without explicit contractual opt-in.

Section 4.02 Sub-Processor Due Diligence & DPAs. Prior to onboarding any third-party cloud vendor or sub-processor that handles Tier 1 or Tier 2 data, the vendor must undergo a formal Security & Privacy Assessment (including SOC 2 Type II verification) and execute a binding Data Processing Addendum (DPA).

Section 4.03 Cryptographic Erasure & Data Subject Rights. Upon contract termination or verified Data Subject Access Request (DSAR), client data shall be permanently purged from active databases within thirty (30) days and rendered unrecoverable via NIST SP 800-88 cryptographic erasure standards.

ARTICLE V: DATA INTEGRITY SAFEGUARDS & INCIDENT RESPONSE

Section 5.01 Immutable Backups & Disaster Recovery. Critical databases and transaction ledgers shall be replicated continuously across geographically redundant availability zones using write-once-read-many (WORM) immutable object locks to prevent ransomware encryption. Disaster recovery failover drills shall be executed semi-annually to validate Recovery Time Objectives (RTO ≤ 4 hours) and Recovery Point Objectives (RPO ≤ 15 minutes).

Section 5.02 Breach Notification SLA. In the event of a confirmed unauthorized disclosure of Tier 1 Restricted client data, the Incident Response Team shall notify affected institutional clients and applicable data protection authorities within seventy-two (72) hours of confirmation.

EXECUTIVE SECURITY & COMPLIANCE AUTHORIZATION

This Policy is mandatory across all engineering, cloud operations, and corporate divisions of FD System Holdings. Non-compliance triggers automated access revocation and formal disciplinary action under the Code of Business Conduct and Ethics.

Approved By: Chief Information Security Officer (CISO) & Office of the General Counsel — **Date: 10/22/2026**